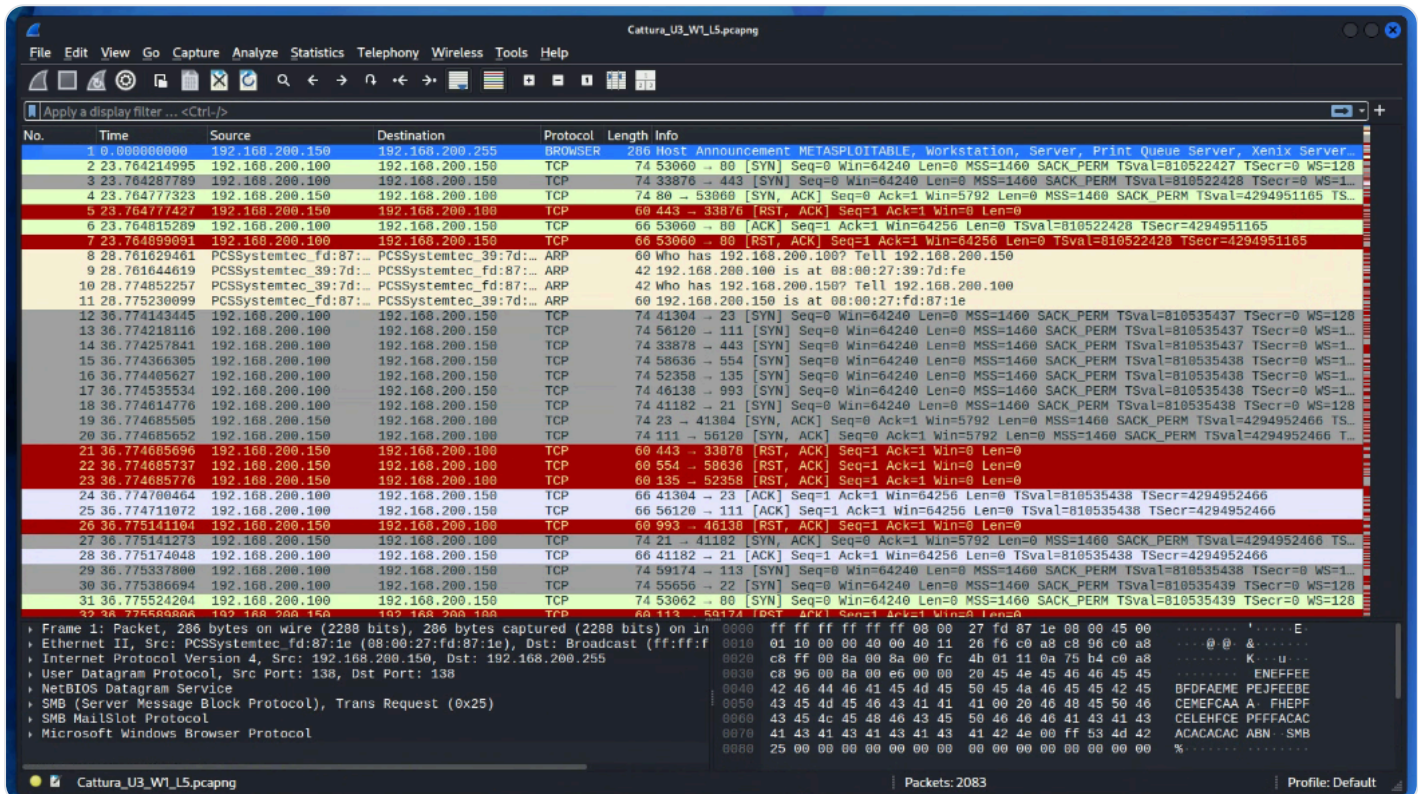


1. Preambolo e ambito operativo

Il presente documento fornisce un'analisi dettagliata e strutturata dell'attività di rete registrata nella cattura PCAP fornita (Cattura_U3_W1_L5.pcapng) con il software di analisi del traffico di rete *Wireshark*. Durante l'analisi sono emerse evidenze chiare di un attacco informatico attivo e condotto in modo sistematico all'interno della rete locale.

L'analisi ha rilevato segnali indicanti una ricognizione di rete e Port Scanning aggressivo (TCP SYN Scan) seguita da una fase di enumerazione dei servizi ed un successivo attacco indirizzato verso servizi specifici esposti dalla macchina bersaglio, che sia ipotizzata sia una macchina *Metasploitable*.



Schermata della finestra del software *Wireshark* in visualizzazione del file di registro del traffico di rete catturato *PCAPNG* Cattura_U3_W1_L5.pcapng

2. Topologia di rete e dispositivi registrati

Dall'analisi dei pacchetti si è potuto rilevare la seguente mappa di rete:

Indirizzo IP	Indirizzo MAC	SO potenziale	Ruolo	Identificazione ed Evidenze
192.168.200.100	08:00:27:39:7d:fe	Kali Linux	Attaccante	Sorgente della scansione massive di porte (SYN Scan), ARP Request/Reply, invio di pacchetti con flag SYN su centinaia di porte distinte.
192.168.200.150	08:00:27:fd:87:10	Metasploitable Server	Vittima	Server Linux con installata la suite Metasploitable (Samba 3.0.20-Debian). Risponde con [SYN, ACK] sulle porte aperte e con [RST, ACK] sulle porte chiuse.
192.168.200.255	ff:ff:ff:ff:ff:ff		Broadcast di Rete	Destinazione per annunci BROWSER/NetBIOS.

3. Identificazione ed analisi degli indicatori di compromissione (IOC)

Nell'analisi degli indicatori di compromissione, ovvero *IOC* (o *Indicators of Compromise*), che rappresentano tracce digitali ed evidenze di sicurezza correlate ad attività malevole o sospette, sono stati individuati una sequenza di connessioni tra l'indirizzo IP 192.168.200.100 , rilevato come il dispositivo attaccante, e l'indirizzo IP 192.168.200.150 , rilevato come il dispositivo vittima.

3.1. Indicatori di compromissione a livello di rete telecomunicativa

Nel file di registro del traffico di rete catturato *PCAPNG* `Cattura_U3_W1_L5.pcapng` , aperto nel software *Wireshark*, si sono notati i seguenti dati:

- L'indirizzo IP 192.168.200.100 è stato notato come dispositivo attaccante.
- L'indirizzo IP 192.168.200.150 è stato notato come dispositivo vittima.
- Il pattern di traffico suggerisce elementi di una manifestazione di un Port scan o di un TCP SYN flood, rilevando:
 - Invio ad altissima frequenza (nell'arco di millisecondi) di pacchetti TCP [SYN] verso una vasta gamma di porte di destinazione casuali/sequenziali dall'host .100 verso l'host .150 .
 - Tra $t = 36.7741s$ e $t = 36.7872s$ (meno di 13 millisecondi), vengono generati oltre 200 pacchetti TCP diretti a porte differenti.
- Esistono elementi di tracce NetBIOS/SMB Browse Slot. particolarmente nella prima istanza di evento catturato, con la stringa
Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Samba 3.0.20-Debian . Inoltre si è notato che l'attaccante ha visibilità diretta del nome host e della versione del servizio Samba in esecuzione sulla macchina vittima.

3.2. IOC comportamentali e tecnici

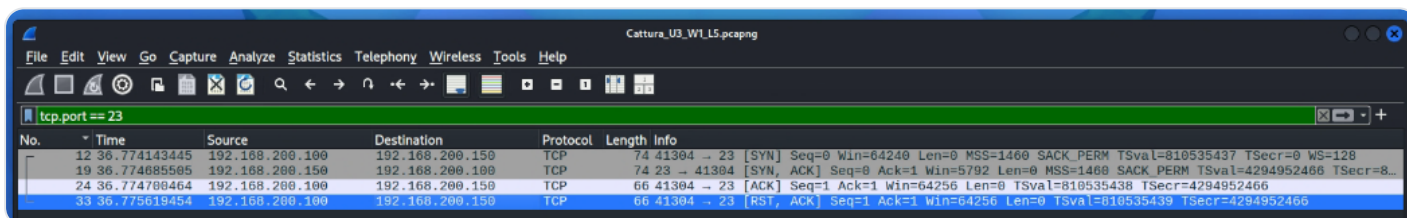
Nell'analisi del registro di cattura di traffico sono risultate 1026 trasmissioni di pacchetti **SYN**, ovvero di richiesta di inizio di connessione verso l'indirizzo IP **192.168.200.100** attaccante per l'intervallo di porte TCP/IP 1-1024. Per lo scenario di connessione tipico alla trasmissione di un pacchetto **SYN** segue la ricezione di un pacchetto **ACK** (o **SYN-ACK**), per la successiva trasmissione di un pacchetto **ACK** che definisce il *three-way handshake*, nelle sequenze di eventi in analisi nel registro di cattura interessato sono stati notati solo 13 eventi con pacchetti **ACK** (o **SYN-ACK**) per le seguenti porte TCP con una sequenza di eventi simile ad un *Handshake TCP*, a partire dall'indirizzo IP **192.168.200.100** attaccante:

Porta TCP origine	Indirizzo IP di destinazione	Porta TCP destinazione	Servizio/protocollo tipico	Sequenza di indicatori	Conteggio eventi
53060	192.168.200.150	80	<i>HyperText Transfer Protocol</i> (HTTP)	SYN, ACK, RST-ACK	3
41304	192.168.200.150	23	Protocollo <i>TelNet</i>	SYN, ACK, RST-ACK	3
56120	192.168.200.150	111	Servizi di bind per chiamate RPC	SYN, ACK, RST-ACK	3
41182	192.168.200.150	21	<i>File Transfer Protocol</i> (FTP)	SYN, ACK, RST-ACK	3
55656	192.168.200.150	22	Protocollo <i>Secure Shell</i> (SSH)	SYN, ACK, RST-ACK	3
53062	192.168.200.150	80	<i>HyperText Transfer Protocol</i> (HTTP)	SYN, ACK, RST-ACK	3
33042	192.168.200.150	445	<i>Server Message Block</i> (SMB)	SYN, ACK, RST-ACK	3
46990	192.168.200.150	139	<i>Server Message Block</i> (SMB) con NetBIOS	SYN, ACK, RST-ACK	3
60632	192.168.200.150	25	<i>Simple Mail Transfer Protocol</i> (SMTP)	SYN, ACK, RST-ACK	3
37282	192.168.200.150	53	<i>Domain Name System</i> (DNS)	SYN, ACK, RST-ACK	3
45648	192.168.200.150	512	<i>Rexec / Remote Execution</i>	SYN, ACK, RST-ACK	3
51396	192.168.200.150	514	Servizio <i>syslog</i>	SYN, ACK, RST-ACK	3
42048	192.168.200.150	513	Servizio di login remoto UNIX <i>rlogin</i>	SYN, ACK, RST-ACK	3

In uno scenario tipico, l'indicatore tipico di connessione con la porta di protocollo TCP prevede l'handshake a 3 vie, ovvero **SYN** (Client → Server - Richiesta di connessione), **SYN-ACK** (Server → Client - Porta aperta, accettazione della connessione), e **ACK** (Client → Server - Conferma finale, la connessione è stabilita).

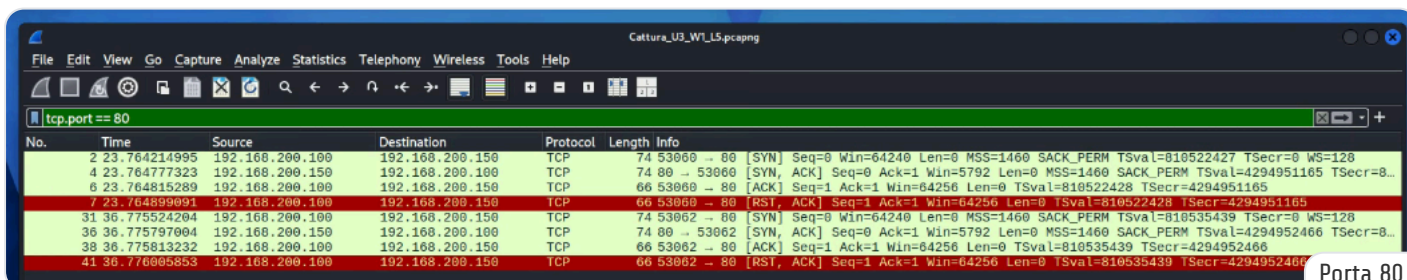
Tuttavia, osservando la sequenza manifestata nei log di cattura (dove all'handshake completo segue immediatamente un pacchetto RST, ACK), si ipotizzano i seguenti scenari:

- Scansione TCP Connect: A differenza della scansione stealth (*SYN Scan*), la scansione TCP Connect sfrutta la chiamata di sistema connect() del sistema operativo dell'attaccante per instaurare un handshake completo a 3 vie (SYN → SYN-ACK → ACK). Non appena la connessione viene stabilita e la porta confermata come aperta, Nmap abbassa immediatamente la sessione inviando un pacchetto RST, ACK per liberare il socket.
- "Abbattimento immediato" dell'applicazione: La porta è aperta a livello di sistema operativo (il kernel completa l'handshake a 3 vie inviando SYN-ACK e ricevendo ACK), ma non appena la connessione passa al software/servizio applicativo sottostante, questo la rifiuta immediatamente (ad esempio per policy di sicurezza, IP non autorizzato o sovraccarico) inviando un RST, ACK.
- Intervento di un firewall/IDS attivo. Per questo scenario un sistema di protezione aziendale (come un IPS o un Firewall Next-Gen) rileva la connessione come malevola o non autorizzata subito dopo la sua instaurazione iniziale ed inietta in seguito un pacchetto RST, ACK falsificato per interrompere la comunicazione tra le due macchine.

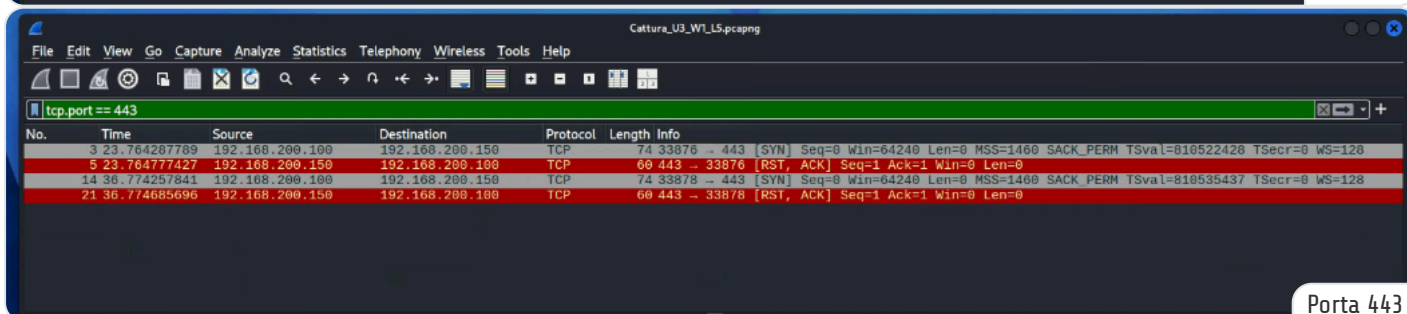


Schermate della finestra del software Wireshark in visualizzazione delle richieste/ricezioni dei pacchetti per la porta TCP/IP 23 del file di registro del traffico di rete catturato *PCAPNG* Cattura_U3_W1_L5.pcapng

Nella stessa analisi si è notato che per le porte TCP/IP 80 e 443, tipicamente relativi ai protocolli *HyperText Transfer Protocol* (HTTP) e *HyperText Transfer Protocol Secure* (HTTPS), come evidenziato nelle catture del software Wireshark, dopo la sequenza iniziale di pacchetti (SYN, ACK, RST-ACK) il traffico registrato mostra la presenza di ulteriori pacchetti aggiuntivi inviati dall'indirizzo IP 192.168.200.100 verso l'indirizzo di destinazione 192.168.200.150 (e viceversa), a conferma delle sonde di scansione e delle relative interruzioni/risposte registrate nel file di cattura interessato.



Porta 80



Porta 443

Schermate della finestra del software Wireshark in visualizzazione delle richieste/ricezioni dei pacchetti aggiuntivi sonda per le porte TCP/IP 80 e 443, del file di registro del traffico di rete catturato *PCAPNG*

Cattura_U3_W1_L5.pcapng

4. Ipotesi sui potenziali vettori di attacco utilizzati

Dall'analisi del registro di cattura di traffico e dagli indicatori di compromissione, si ipotizzano i seguenti vettori di attacco utilizzati:

- Software *Nmap* con l'argomento di TCP Connect Scan `-sT` e gli argomenti `-p 1-1024`, `-sV` (o `-PS80,443`) e `--max-retries 0`, dove in questo scenario si ipotizza una scansione dell'intervallo di porte 1-1024 per individuare rapidamente i servizi attivi completando la maggior parte degli handshake TCP, con trasmissione (tramite l'argomento `-sV` o `-PS80,443`) di pacchetti *sonda* aggiuntivi verso le porte 80 e 443, tipicamente attribuibili ai protocolli HTTP e HTTPS.
- *Exploitation* di Samba 3.0.20 (CVE-2007-2447 - `usermap_script`), dove in questo scenario si ipotizza, con la porta 139/445 aperta e la versione identificata Samba 3.0.20-Debian, un sistema gravemente esposto all'esecuzione remota di codice arbitrario con privilegi root senza autenticazione. Si presume, tuttavia, che l'effettiva esecuzione di questo exploit sia avvenuta in un momento successivo rispetto agli eventi registrati nel file PCAPNG analizzato.
- Attacchi *Brute force* e/o attacchi di dizionario con credenziali di Default ai servizi tipici delle porte TCP 21 (ovvero *File Transfer Protocol*) e 22 (ovvero servizio *Secure Shell*, o SSH). Si presume, tuttavia, che l'effettiva esecuzione di questo exploit sia avvenuta in un momento successivo rispetto agli eventi registrati nel file PCAPNG analizzato.
- Abuso di servizi legacy *R-Services* (512 - `rexec`), dove si ipotizza la presenza di servizi di esecuzione remota non cifrati e vulnerabili ad accessi non autorizzati. Si presume, tuttavia, che l'effettiva esecuzione di questo exploit sia avvenuta in un momento successivo rispetto agli eventi registrati nel file PCAPNG analizzato

5. Azioni di mitigazione degli attacchi

Per ridurre l'impatto dell'attacco in corso e prevenire incidenti simili in futuro, si consiglia l'applicazione delle seguenti azioni di mitigazione:

- segregazione del dispositivo host all'indirizzo IP 192.168.200.150 dalla rete per l'evitamento di azioni di attacco da accessi laterali da parte dell'attaccante.
- configurazione e implementazione di regole di *firewalling* al fine di bloccare i pacchetti di rete provenienti dal dispositivo dell'indirizzo IP 192.168.200.100
- interruzione dei servizi ridondanti/non strettamente necessari, come i servizi *Samba*, *File Transfer Protocol* (FTP) e servizi di login remoto UNIX *rlogin*
- aggiornarnamento del servizio *Samba* all'ultima versione stabile per la correzione della vulnerabilità CVE-2007-2447.
- Implementazione di Intrusion Detection & Prevention Systems (IDS/IPS)
- Adozione di una politica di Zero Trust e segmentazione tramite VLAN / Firewall interni, e limitazione dell'accesso alle porte di gestione (SSH, SMB) solo a subnet amministrative autorizzate.
- Implementazione di operazioni di monitoraggio del log di sistema e di rete su piattaforme SIEM per analisi in tempo reale di eventi di *port scanning*

6. Conclusioni

L'analisi svolta sul file PCAP ha evidenziato con chiarezza la presenza di un'attività aggressiva di reconnaissance condotta dall'indirizzo 192.168.200.100 nei confronti del server 192.168.200.150. L'identificazione tempestiva degli IOC e delle vulnerabilità associate ai servizi esposti (in primis Samba 3.0.20) consente di applicare tempestivamente le opportune contromisure prima che l'attaccante possa completare la fase di exploitation e compromettere l'integrità del sistema.